

Risk Register

Inherent payment-security risk scenarios, treatments, target scores and accountable owners.

Document ID	PCI-V2-RR-005
Prepared by	Richmond Kwadwo Sarpong
Case study	Akwaaba Retail & Online Ltd. (fictional)
Date / version	20 August 2026 / Version 2.0

Independent fictional portfolio case study - not a Report on Compliance, Attestation of Compliance, QSA assessment, or evidence of work performed for a real merchant.

Risk Scoring

Likelihood (L) x Impact (I). 20-25 Critical; 12-19 High; 6-11 Medium; 1-5 Low. Target scores assume successful control implementation and validation.

ID	Risk scenario	Asset / process	L	I	Score	Rating	Treatment	Target	Residual	Owner
R-01	PAN exposure through application debug logs	Payment application / logs	5	5	25	Critical	Stop logging; delete securely; validate masking	5	Low	CISO / A
R-02	Unauthorized CDE access because MFA is incomplete	CDE administration	4	5	20	Critical	MFA, unique IDs, access review and monitoring	8	Medium	IAM Lea
R-03	E-skimming through unauthorized payment-page scripts	Checkout page	4	5	20	Critical	Script inventory, authorization, integrity and tamper detection	8	Medium	Enginee
R-04	Exploitation of overdue critical vulnerabilities	Public web platform	4	5	20	Critical	Emergency patching and enforceable patch SLA	5	Low	Infrastru
R-05	Lateral movement through broad network access	CDE network	3	5	15	High	Least-access firewall rules and segmentation test	6	Medium	Network
R-06	Delayed detection because key logs are not reviewed	SIEM / CDE logs	4	4	16	High	Daily review, alert use cases and investigation workflow	8	Medium	SOC Lea
R-07	Third-party control failure remains unidentified	Gateway / cloud / CDN	3	4	12	High	AOC review, responsibility matrix and annual monitoring	6	Medium	Complia
R-08	POS device substitution or tampering	Retail POS devices	3	4	12	High	Device inventory, inspection, training and escalation	4	Low	Retail O
R-09	Card data interception through weak transport settings	Legacy support channel	3	4	12	High	Strong TLS, certificate control and endpoint retest	4	Low	Network
R-10	Ineffective response to a payment-data incident	Organization-wide	3	5	15	High	Tested IR plan, roles, contacts and evidence handling	6	Medium	CISO

Management Review Expectations

- Critical risks require immediate containment, executive visibility and time-bound remediation.
- Risk owners should document treatment progress, exceptions, target dates and evidence of control effectiveness.
- Residual risk acceptance should be explicit, time-bound and approved by an appropriate authority.
- The register should be reviewed at least quarterly and after material changes or security incidents.